

UNIVERSIDAD TÉCNICA ESTATAL DE QUEVEDO

FACULTAD DE CIENCIAS DE LA COMPUTACIÓN

CARRERA DE INGENIERÍA DE SOFTWARE

ISR-401 · INGENIERÍA DE REQUISITOS

ANÁLISIS DE RIESGOS Y MEDIDAS DE MITIGACIÓN

Riesgos éticos, técnicos, operativos y reputacionales

Código	PFC-ISR401-FG-RIS-11	Versión y fecha	Versión 3.0 · 29 de julio de 2026
Proyecto	Proyecto académico Fabro Gym	Equipo	Equipo PFC - Gimnasio · Paralelo Software A
Sistema	Sistema de gestión administrativa y operativa para un gimnasio	Docente responsable	Ing. Gleiston Guerrero Ulloa, PhD
Repositorio	https://github.com/amorad35/FabroGym_ISR401.git		
Clasificación ética	Categoría A - Datos potencialmente sensibles; uso exclusivo de datos disociados o sintéticos		

1. Escala

La probabilidad se valora como Baja, Media o Alta; el impacto como Bajo, Medio o Alto. El nivel resultante se expresa como Bajo (verde), Medio (celeste) o Alto (rojo). Cada riesgo conserva al menos una medida de mitigación y una evidencia de control.

Matriz de riesgos							
ID	Tipo	Evento de riesgo	Prob.	Impacto	Nivel	Prevención / respuesta	Responsable / evidencia
R-01	Ético	Participación bajo presión laboral o académica	Media	Alto	Alto	Explicar voluntariedad, reclutar sin jefatura presente y permitir retiro.	AV / consentimiento
R-02	Ético	Incomodidad al comentar fallas internas	Media	Medio	Medio	Permitir omitir preguntas, pausar o terminar la sesión.	Entrevistador / acta
R-03	Privacidad	Publicación accidental de nombres, firmas o contactos	Media	Alto	Alto	Doble revisión, versión pública redactada y bloqueo de carpetas identificables.	PR / checklist
R-04	Privacidad	Reidentificación por cargo único o combinación de detalles	Media	Alto	Alto	Generalizar roles, retirar ubicaciones y agregar resultados.	PR / matriz
R-05	Categoría A	Captura de peso, lesión, diagnóstico o biometría real	Media	Alto	Alto	Excluir preguntas y campos; revisar instrumentos y detener la captura.	Docente / instrumentos
R-06	Seguridad	Acceso no autorizado a audios o consentimientos	Media	Alto	Alto	Zona restringida, 2FA, mínimo privilegio, revocación de enlaces.	VO / registro accesos
R-07	Seguridad	Credenciales o secretos incluidos en GitHub	Media	Alto	Alto	Revisión previa al commit, variables seguras y rotación inmediata.	VO / historial
R-08	Reputacional	Hallazgo presentado como acusación contra un gimnasio	Media	Alto	Alto	Lenguaje neutral, códigos GYM, agregación y revisión del docente.	PR / informe
R-09	Reputacional	Uso de marca o nombre sin autorización	Media	Medio	Medio	Anonimizar por defecto y solicitar autorización escrita específica.	AV / aval
R-10	Técnico	Pérdida o corrupción de evidencia	Media	Medio	Medio	Respaldo institucional controlado, checksum y versiones.	VO / bitácora
R-11	Técnico	Duplicidad o inconsistencia de requisitos	Media	Medio	Medio	Identificadores únicos, trazabilidad y revisión cruzada.	MD/PR / matriz
R-12	Operativo	Baja participación o muestra incompleta	Alta	Medio	Alto	Contactar varios gimnasios, documentar tasa y reconocer limitación.	AV / registro
R-13	Operativo	Falla de grabación o conectividad	Media	Bajo	Bajo	Notas manuales, prueba previa y reprogramación voluntaria.	Entrevistador
R-14	Calidad	Preguntas sesgadas o ambiguas	Media	Medio	Medio	Piloto, revisión por pares y control de versiones.	MA/PR / piloto
R-15	Calidad	Resultados de conveniencia generalizados indebidamente	Media	Medio	Medio	Análisis descriptivo y declaración de límites del muestreo.	MA / informe
R-16	Legal	Retención superior a la finalidad declarada	Media	Alto	Alto	Calendario de eliminación y acta de destrucción.	VO / acta
R-17	Terceros	Plataforma virtual conserva copias no controladas	Media	Medio	Medio	Configurar retención, descargar solo lo necesario y eliminar copias.	VO / checklist
R-18	Cambio	Se incorpora biometría sin nueva aprobación	Baja	Alto	Medio	Control de cambios; suspensión y nueva revisión ética.	Docente / acta CCB

2. Respuesta a incidentes

1. Contener: retirar enlaces, suspender accesos y evitar nuevas copias.
2. Preservar evidencia mínima: fecha, archivo, cuenta, alcance y acción tomada.
3. Notificar al docente y al responsable de evidencias dentro de 24 horas; elevar el reporte institucional en un máximo de 72 horas.
4. Evaluar afectación, corregir permisos, rotar credenciales y contactar a participantes cuando corresponda.
5. Documentar causa, acción correctiva y actualización de esta matriz.